

Chapter 13 — Compromise Recovery, Offensive Assurance, Audit, and Security Certification Inputs

1. Document control

- Identifier: HAL-BVI-13
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern eradication, recovery from independently verified foundations, penetration testing, red teaming, independent assessment, audit preparation, and evidence supplied to Book VIII.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 22, 26, 40, 42-44, 47, 58
- Book II: Chapters 2, 28, 30-33, 35
- Book III: Chapters 6-9
- Book IV: CMP-15-18, CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Recovery Coordinator, Security Assessor, Red Team Lead, Audit Lead, Evidence Custodian, Certification Liaison.

6. Normative controls

VI-ASR-13-001 — Recover from independently verified foundations

Compromise recovery MUST re-establish measured hardware or host integrity, immutable identity, current Authority, protected configuration, verified artifacts, evidence integrity, and authoritative state before restoring capability.

- Applicability: compromise recovery
- Responsible role: Recovery Coordinator
- Enforcement: recovery admission gate
- Required evidence: Recovery Admission Record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-002 — Scope eradication to dependencies

Eradication **MUST** address persistence, credentials, keys, images, builds, dependencies, policies, data, peers, Treaties, caches, backups, and compromised evidence—not only the initially affected host.

- Applicability: confirmed compromise
- Responsible role: Recovery Coordinator
- Enforcement: dependency impact checklist
- Required evidence: eradication evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-ASR-13-003 — Require post-recovery verification

Restored systems **MUST** complete risk-based Book VIII verification, including containment, authority paths, privacy, trust boundaries, recovery invariants, and regression, before protected work resumes.

- Applicability: restored systems
- Responsible role: Certification Liaison
- Enforcement: verification admission status
- Required evidence: Book VIII result reference
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-004 — Authorize offensive testing

Penetration tests and red teams **MUST** have written scope, targets, time, allowed techniques, data handling, safety boundaries, stop authority, escalation, evidence, and cleanup before execution.

- Applicability: offensive tests
- Responsible role: Red Team Lead
- Enforcement: rules-of-engagement gate
- Required evidence: signed engagement plan
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-ASR-13-005 — Test both attacker and overreach paths

Adversarial work **MUST** test compromise of HAL and misuse or excess of HAL Authority, including stale delegation, trust confusion, Treaty bypass, evidence suppression, and unauthorized external effect.

- Applicability: high-risk systems
- Responsible role: Security Assessor
- Enforcement: scenario coverage review
- Required evidence: adversarial assessment
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-006 — Remediate findings with independent closure

Offensive and audit findings **MUST** enter the common risk process and close only after deployed remediation, independent retest, residual-risk decision, and affected-assurance review.

- Applicability: all findings
- Responsible role: Security Assessor
- Enforcement: finding workflow
- Required evidence: retest and closure record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-ASR-13-007 — Prepare auditable evidence

Audit packages **MUST** state scope, criteria, sources, sampling, limitations, control owners, evidence locations, access decisions, exceptions, findings, remediation, and unresolved risk without fabricating assurance.

- Applicability: audits
- Responsible role: Audit Lead
- Enforcement: audit readiness review
- Required evidence: audit evidence manifest
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-ASR-13-008 — Supply but do not issue certification

Book VI **MUST** supply security, privacy, trust, incident, recovery, and control-effectiveness evidence to Book VIII; Book VI roles **MUST NOT** issue or redefine certification unless separately authorized there.

- Applicability: certification inputs
- Responsible role: Certification Liaison
- Enforcement: Book VIII reconciliation gate
- Required evidence: assurance evidence package
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 22, 26, 40, 42-44, 47, 58
- Book II: Chapters 2, 28, 30-33, 35
- Book III: Chapters 6-9
- Book IV: CMP-15-18, CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.